

Co2 - Assessment Tool - 3

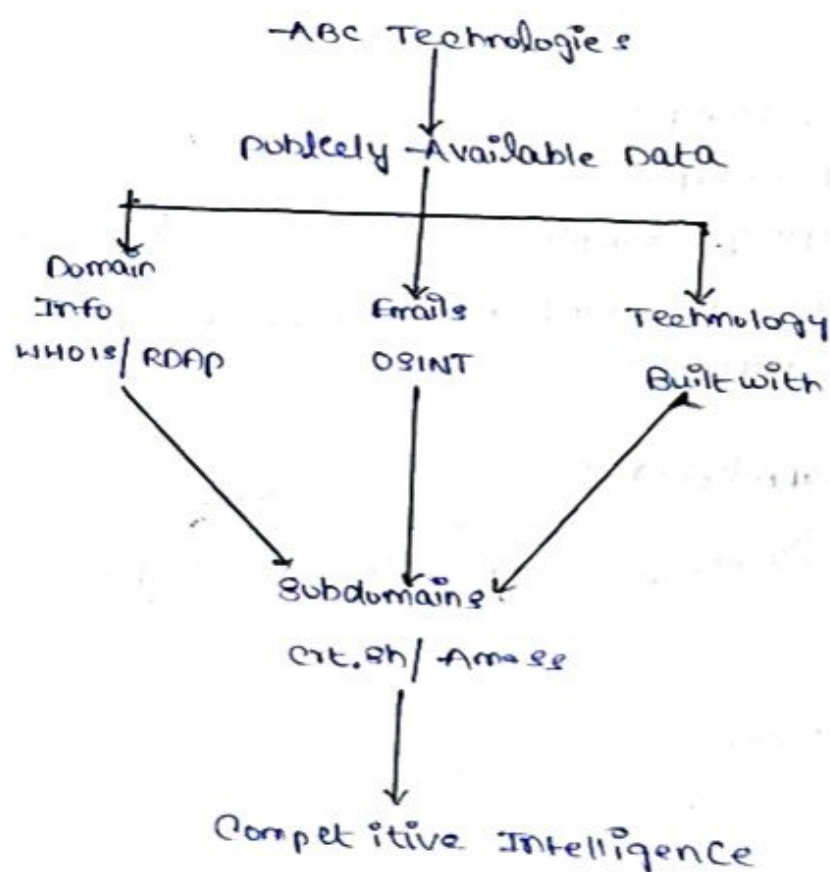
1) Footprinting Tools - Conquering Competitive Intelligence

Introduction

Footprinting is the process of collecting information about an organization from publicly available sources. In this scenario, the Consultant performs a passive assessment, so there is no direct interaction with ABC Technologies' services.

The main information to collect is domain details, employee emails, technology stack, and public subdomains.

Footprinting Diagram



1) WHOIS / RDAP

WHOIS/RDAP provides publicly available domain registration information such as:

- Domain name
- Registrar
- Registration dates
- Name servers
- Domain status

Use: It helps understand the organization's domain and DNS infrastructure.

2) Search Engines / the Harvester

Search engines and OSINT tools such as the Harvester can identify publicly exposed employee names, email addresses and organization-related information.

Ex:

john@company.example

hr@company.example

support@company.example

Use: This helps understand public contact information and email naming patterns.

3) BuiltWith / Wappalizer

These tools identify technologies used by a website such as:

- Web server
- JavaScript frameworks
- CMS
- Analytics tools
- CDN technologies

Use: It helps understand the company's publicly visible stack.

4) Crt.sh / Amass

Certificate Transparency records and passive Amass searches can reveal publicly visible subdomains.

Ex:

www.company.example
mail.company.example
portal.company.example
dev.company.example

Use: This helps identify the organization's public digital assets.

Conclusion

passive footprinting provides useful intelligence without directly attacking the organization's systems. It helps security professionals understand the company's public exposure and identify information that should be protected.

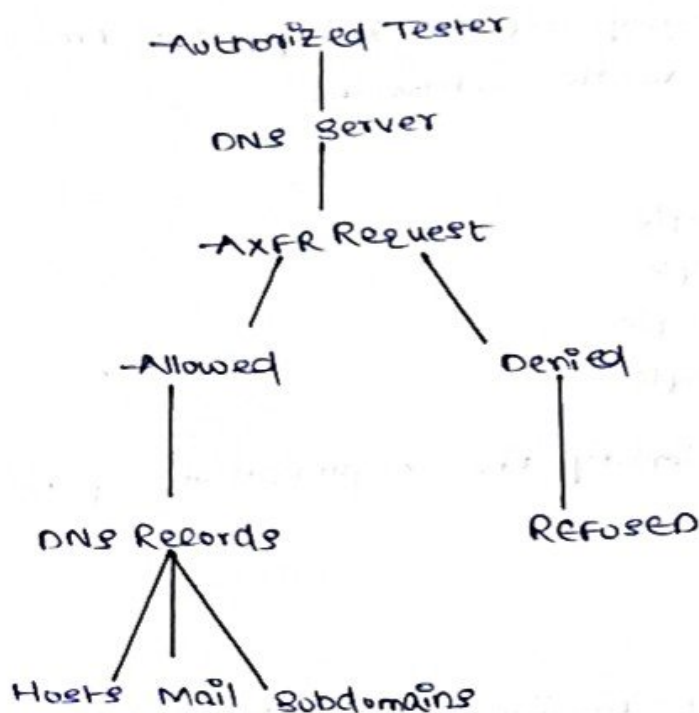
2) DNS Zone Transfers

Introduction

A DNS zone transfer is used to copy DNS information b/w DNS servers. If it is incorrectly configured an authorized user may be able to obtain many DNS records.

During an authorized penetration test the analyst can test whether zone transfers are allowed.

DNS Zone Transfer Diagram



Command using dig

The analyst can use:

`dig AXFR example.com @ns1.example.com`

Here

- dig - DNS lookup tool
- AXFR - requests a full zone transfer
- example.com - authorized target domain
- ns1.example.com - DNS server

The actual target values should only be used when authorized

Using nslookup

nslookup

server ns1.example.com

ls -d example.com

If the server returns Refused the zone transfer is restricted.

If it succeeds the response may contain records such as:

www.example.com

mail.example.com

vpn.example.com

dev.example.com

Information obtained

→ A successful transfer may reveal:

1) Internal/host names:

Helps identify servers and other systems

2) Mail servers:

MX records can show the organization's mail infrastructure.

3) Security domains:

- Restrict AXFR to authorized secondary DNS servers
- Configure DNS access control lists
- Monitor unusual zone-transfer requests.
- Regularly audit DNS configuration.

Conclusion:

→ An unrestricted DNS zone transfer can expose important reconnaissance information.

→ Therefore organizations should allow zone transfers only to trusted and authorized DNS servers

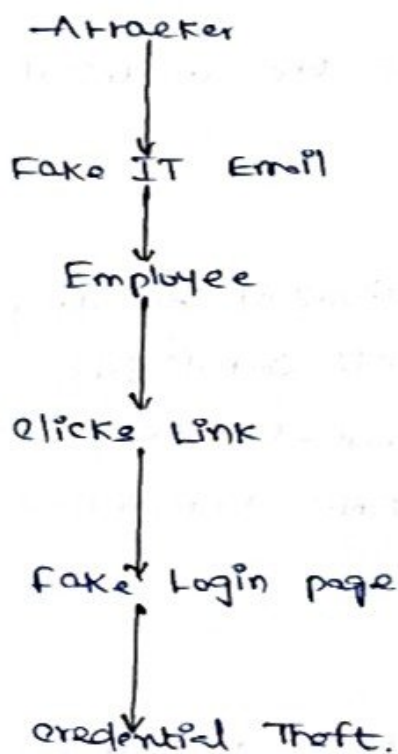
3) Social Engineering - Attack and Countermeasures.

Identification of Attack

The email describes in the scenario is a phishing attack

The attacker pretends to be from the IT department and uses urgency and authority to convince employees to provide their login credentials.

phishing Diagram



Countermeasures

- 1) Do Not click the Link

Employees should not immediately click links in unexpected emails

- 2) Check the sender

The employee should carefully verify the sender's email address and domain.

3) Check the URL

A suspicious or misspelled domain may indicate a phishing website.

4) Verify with IT

Employees should contact the IT department using an official phone number, help desk, or internal portal not the contact information in the suspicious email.

5) Never share passwords

Employees should never enter passwords into an unverified website, or send passwords through email.

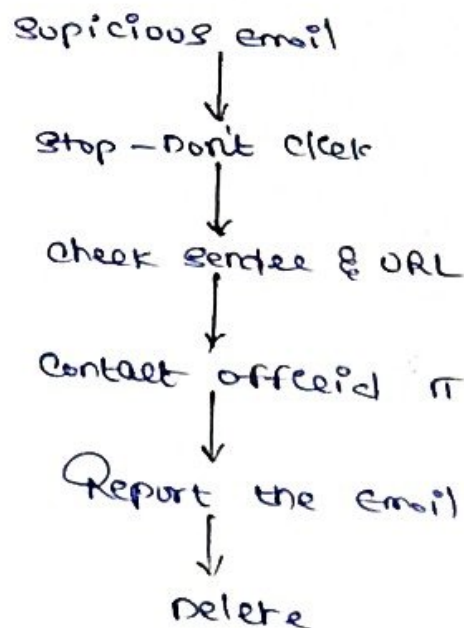
6) Report the email

The suspicious message should be reported to the organization's IT / security team

7) Use MFA

Multi-factor authentication provides an additional security layer if a password is compromised

Prevention flow



How These Measures Prevent Credential Theft.

These actions prevent employees from reaching fake login pages and entering their usernames and passwords. Independent verification also helps confirm whether the request is actually from the IT department.

Conclusion

phishing attacks mainly exploit human trust and urgency. Employee awareness, email verification, reporting procedures, strong passwords and MFA can significantly reduce the risk of credential theft.